

Your OT environment, made visible.

A digital twin is a computable replica of a physical thing, accurate enough to run experiments on instead of the plant. The OXOT **Cyber Digital Twin** carries a plant's security state alongside its engineering state: the firmware each controller is running, the pathways between them, the vulnerabilities on those pathways and the adversaries who use them. Attack the replica, and you learn what would happen to the original.

THE PROBLEM

Industrial environments were not built for today's cyber reality.

Legacy technology, fragmented asset information and growing IT/OT connectivity make it hard to see where real risk sits. Remote access, supply-chain dependency and an evolving threat landscape keep widening the attack surface while regulation demands more control.

And unlike IT, change itself carries risk: improvements must be made in live, safety- and availability-critical plants where downtime is not an option.

The challenge is not finding security issues.

It is knowing what matters most, what can safely be changed, and what to do first.



01

See your OT environment

02

Understand the risk

03

Know what to do next

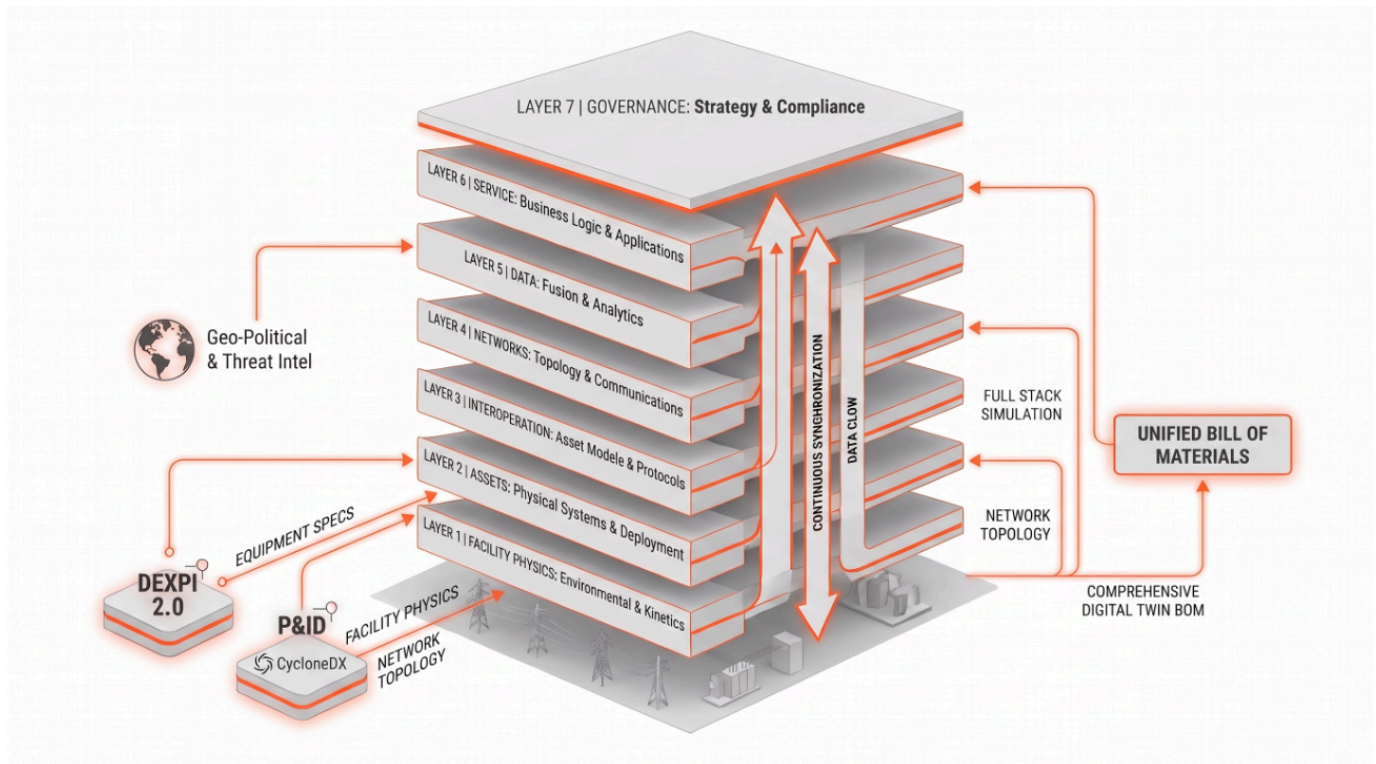
WHAT IT IS USED FOR

Identify and assess cyber risk	Test scenarios before changing the live environment
Understand which systems and dependencies matter most	Recommend and prioritise security controls
Compare investment options by risk reduction	Support IEC 62443, NIS2, CRA, AI Act and Machine Act

SEVEN LAYERS

Layer one is not a firewall. It is physics.

A plant is mass, pressure, heat and time, held inside tolerances set decades before anything in the building was addressable. Model it as IT infrastructure and you have already discarded the property that makes it dangerous. So the twin is built the way the plant was built — from the ground up, each layer carrying what the layer below cannot explain about itself, and every layer above the first inheriting a physical consequence from it.



The engineering half

What each item does in the process, what fails when it misbehaves, and which safety function is supposed to catch that failure. Failure-mode analysis, the reliability-critical items list and the safety-critical items list live here — alongside minimum operating requirements.

The cyber half

The firmware it is actually running, the software beneath that, the cryptography protecting it, the pathways into it and the vulnerabilities on those pathways — held as versioned, diffable bills of materials in CycloneDX.

BUILT FROM YOUR OWN RECORD

P&IDs, DEXPI 2.0 exports, equipment specifications, network topology and existing inventories — not a reference architecture. IEC 62443 and TS 50701 are structure rather than appendix, so zones and conduits partition the model itself. Passive-first: nothing installed on your controllers.

ONE MODEL, MANY LENSES

The same object projects as a P&ID, a Purdue diagram, a network map, a dependency graph and a 3D site view — so the process engineer, the network architect, the safety authority and the board stop arguing about which document is current. Drill it five levels: component to organization.

CONSEQUENCE FIRST

Consequence, then probability, then price.

Most of the industry runs this backwards, starting from a vulnerability score and working towards a guess about impact. Consequence has to come first, because it is the part that is genuinely knowable: the engineering tells you what happens when a specific thing fails, and which safety function is supposed to catch it. Probability is then a question about pathways. Price is arithmetic.

FMECA

Failure mode, effects and criticality analysis for each component — what breaks, how, and what follows.

RCIL

Reliability-critical items: the equipment minimum operations actually depend on.

SCIL

Safety-critical items, mapped to the safety functions that are meant to protect against them.

EXPLOITABILITY

A pathway, not a severity number.

Every asset in the twin is enriched with known-exploited status, exploit probability, technical severity and adversary technique — then scored by whether an attacker can actually reach it through your topology. A critical CVE on an unreachable asset is not a critical risk, and saying so in writing is how a backlog becomes a plan.

KEV

Known to be exploited in the wild

EPSS

Probability of exploitation

CVSS

Technical severity, in context

ATT&CK

Techniques mapped to the pathway

FIVE BILLS OF MATERIALS

Machine-readable inventory in CycloneDX, versioned and diffable, with transitive dependencies traced — so a vulnerability five libraries deep still surfaces, and the CRA technical file is generated rather than written.

SBOM — software, to the library

HBOM — hardware and firmware

CBOM — cryptography, including post-quantum exposure

SaaS-BOM — cloud services in the estate

Ops-BOM — how the plant is actually operated

LOSS IS ENGINEERED, NOT ESTIMATED

The severity of a failure is not something a security tool should be guessing at — your own professional engineers have already quantified it. The twin integrates that work rather than replacing it, so the euro figure rests on the organisation's own engineering judgement.

Safety — FMEA severity, already assessed and signed off

Reliability — loss of production, and loss of product quality

Minimum operating requirements — what must keep running, and for how long

Production scheduling — the cost of an interrupted or reordered campaign

A cyber pathway inherits the loss figure the engineering already carries. Nothing is invented at the security layer.

WORLD MONITOR

Risk does not stop at the fence line.

Every facility sits somewhere, and where it sits changes what can happen to it. WorldMonitor tracks real-time geopolitical, economic, military and environmental pressure across nine specialised domains and binds it to each site's actual location — so the model's answer moves when the world moves, before any incident occurs. This is an input to the simulation, not a separate report on a different desk.

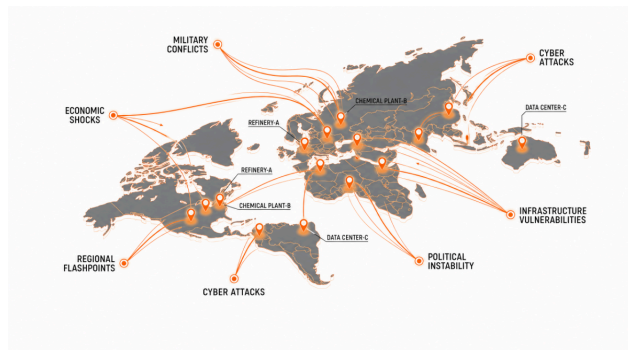
COUNTRY AND CASCADE

31-Country Instability Index — governance, stability and conflict signals per country, refreshed as conditions change

Cascade analysis — how an infrastructure failure elsewhere propagates into your operation

Value chain — upstream and downstream partners continuously assessed; their outage is your outage

Supplier rating — vendors and products scored on track record, for procurement



External pressure bound to each site's real location — conflict, economics, instability and infrastructure exposure.

NINE MONITORED DOMAINS

News & geopolitics	Military & security	Maritime & aviation
Cyber & infrastructure	Climate & disasters	Energy & commodities
Finance & economy	Government & supply chain	Nuclear & strategic facilities

WHO IS COMING, AND WITH WHAT

ATQ — attacker behavioural profiles: capability, motivation and how dangerous each actor is to this facility

TACAM — cyber threats, vulnerabilities, TTPs and KEV-enriched exposure, fingerprinted across seven dimensions: techniques, sector, geography, OT protocol, tempo, products and weaknesses

Crossed together they answer which actors target your sector using your vendors' products, and who is converging on you this quarter. External pressure supplies the likelihood; your own engineering supplies the loss. The twin is where the two meet.

WHAT THIS CHANGES

Risk becomes site-specific

Two identical plants in different countries do not carry identical risk, and the model stops pretending they do.

Leading, not lagging

Pressure signals move the forecast before an incident occurs, rather than explaining one afterwards.

Procurement carries evidence

Supplier and product history is attached to the buying decision, not discovered after installation.

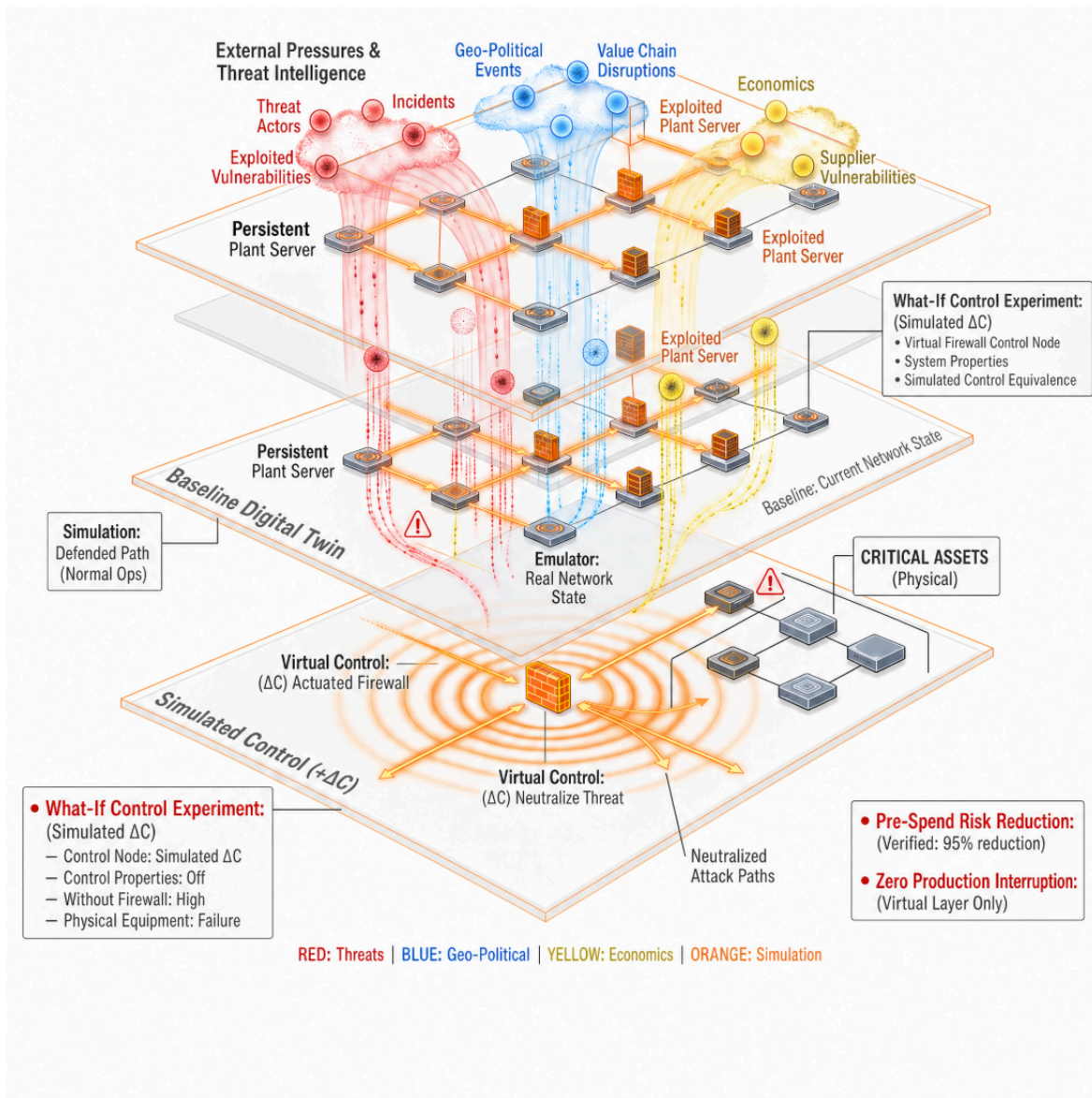
The number moves on a Tuesday when nothing inside the fence was touched.

That is the point of watching the outside world: the plant did not change, but its exposure did.

SIMULATION

Buy the control after you have watched it work.

Threat activity, geopolitical events, economic pressure and supplier weakness all bear down on the same modelled plant. Because the twin is a model, a control can be added to it before it is added to the plant: place the firewall virtually, redraw the segmentation, apply the patch campaign — then re-run the campaigns and compare the distributions. The difference between them is the risk that control actually buys.



Baseline

The network as it is — real topology and state, with the pathways to a critical asset.

Pressure applied

Threat actors, exploited vulnerabilities, geopolitics, economics and supplier exposure as model inputs.

Simulated control (ΔC)

The candidate exists only in the virtual layer — you see which paths it neutralises and which it misses.

Pre-spend

Quantified before procurement, tested without touching production. A business case, not a hope.

WHAT YOU CAN TEST

Capital purchases Score competing products and vendors against the same distribution before the order is placed.	Configuration changes Segmentation, firewall rules and patch campaigns rehearsed in the model rather than in the plant.	Drift and accidents Monte Carlo walks explore the alternate histories too — the change nobody logged, the drift of three quiet years.
--	---	---

DIMINISHING RETURNS

Spend does not buy risk reduction in a straight line.

Early investment compounds; then the curve flattens, and past a point more money buys almost nothing. The engine maps that response surface for your estate and finds the ridge — where the return on each additional euro is highest, and where it stops paying.

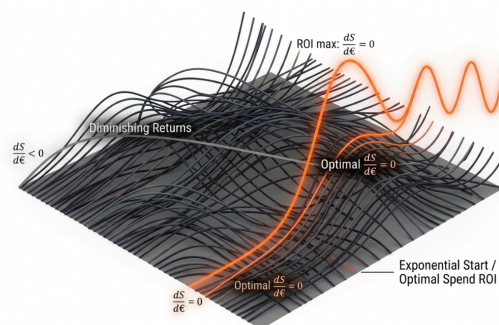
That is what turns a quantified risk into an actionable one: a bounded recommendation rather than an open-ended ask.

THE TAIL IS PRICED SEPARATELY

Industrial cyber loss is fat-tailed: one adversary reaching one safety-critical system produces a loss far beyond the mean, and averaging never surfaces it. Monte Carlo simulation returns a full loss distribution with confidence intervals, and the conditional value at risk of the tail is stated apart from the central estimate.

SURVIVE FIRST, OPTIMISE SECOND

A programme that lowers average risk while leaving ruin risk intact has spent money and bought nothing. So the ridge is read against the tail, not instead of it: the optimal spend is the one that removes the scenarios you cannot survive before it optimises the ones you can.



Risk reduction against spend: exponential start, ROI ridge, then diminishing returns.

DELIVERY

Island Mode Isolated. On you own ground, No external dependencies. No access to control systems. Your own custom AI Model.	One Way Data-Diode A Data Diode limits data to inbound only. This allows our intelligence to stream into the Cyber Digital Twin. But nothing exits.	Dedicated Instance A Single-tenant instance located in an AWS service of your choice. Align to your Data Sovereign Requirements.	Integrations We integrate with Asset Management, Historians, Network Monitoring and Service Management applications.
---	--	---	--

WHAT THE RIDGE GIVES YOU

A bounded number A spend recommendation with a stated ceiling, not an open-ended ask — and the point beyond which more money stops paying.	Comparable options Competing controls, vendors and sequencing scored against the same distribution, so the comparison is like for like.	A roadmap that orders itself Every finding carries the risk it removes per euro, so the programme sequence falls out of the model rather than out of a workshop.
--	---	--

PRIORITISATION

Three answers, and the discipline to use the third.

Findings are triaged by consequence against exploitability rather than by severity score. NEVER is the one that changes how a team works: a documented decision to leave something alone because the model says it cannot hurt you — which is how a backlog of four hundred items stops behaving like an unpriced liability.

NOW

Reachable pathways to safety-critical systems and crown jewels. These are the ruin scenarios, and they are not a budget question.

NEXT

Real exposure, survivable, worth fixing on merit — sequenced by how much of the distribution each euro removes.

NEVER

Unreachable, or reachable with no consequence — written down with the reasoning, so the decision survives an auditor and a staff change.

WHAT IT PRODUCES

The Consequence Index

One organizational rating, rolled up from equipment to enterprise and priced in euros on a 90-day trend.

Annual loss expectancy

Grounded in published breach frequency, claims severity and disclosed losses — defensible to an underwriter.

Glass box

Never underwrite a number you cannot take apart: every figure drills to the evidence that produced it.

HOW AN ENGAGEMENT RUNS

Ingest — Our enigneers work with your real engineering documents, P&ID, Maintenance procedures, Network diagrams, Critical Registers, Configs, Asset inventories

Reconcile — our engineers work through the model with your process, network and safety teams

Sustain — change a component and the BOMs, risk deltas and file sections regenerate as differences

COMPLIANCE, FROM THE SAME MODEL

IEC 62443 · TS 50701 — zones, conduits, security levels

NIS2 — risk picture and supplier dependencies

Cyber Resilience Act · AI Act · Machine Act — Annex VII and the rest, generated

WHERE THE ENGINE CAME FROM

The Cyber Digital Twin was born from delivering M&A due diligence on a deal clock: whole industrial estates assessed properly, in weeks, without walking every site. That constraint produced the Seldon Engine — and it is why every engagement starts from a model rather than a checklist.

WHO BUILDS IT

OXOT is a Dutch OT security practice staffed from process and control engineering, industrial networks and safety. The Dutch government and the European Cybersecurity Competence Centre co-invested in the Cyber Digital Twin under CIF-NL 2025.

One environment. One evolving model. Better security decisions.

Contact Us @ info@oxot.nl

The Consequence Index, ALE and simulations are OXOT's own transparent, drillable calculations, directionally validated on real engagements — not rating-agency or actuarial marks. Sample figures are illustrative, not customer data.